

テスト設計書

チケット管理アプリ(Web, Django + SQLite)

GitHub リポジトリ [qa/docs/30_test_design.md](#) の Word 体裁版(正本と同一内容)

項目	内容
文書ID / 版	TD-TICKET-001 / v1.6(ステータス:Approved)
最終更新 / 作成者	2026-06-13 / 仁後慎太郎
対象	チケット管理アプリ(Web, Django + SQLite)
テストベース	要求仕様 42件(requirements.csv) / app 仕様書(RBAC・状態遷移)
関連	10 テスト計画・20 テスト条件・30 テスト設計・70 トレーサビリティ・80 テスト層戦略 / testcases.csv(TC-001~046)

1. 目的

テストベースから、優先度付きのテスト条件を導き、代表的なテストケースへ落とし込む設計方針を示す。認可(RBAC)・状態遷移・入力検証という業務アプリの品質リスクを、適切なテスト技法で体系的にカバーすることを狙う。

2. テスト技法(採用)

- 同値分割・境界値分析:タイトル / 本文 / 期限 / 添付サイズ
- 状態遷移テスト:ステータス遷移の許可 / 禁止
- デシジョンテーブル:ロール × 操作(参照 / 更新 / 割当)の認可
- 探索的テスト:チャーターに基づき追加のテスト条件を抽出

3. モデル

3.1 状態遷移モデル(State Transition)

Create は Requester が実行可能(Admin 作成は Should 要件として Backlog 管理)。Update(ステータス変更)は Admin または担当 Agent が実行可能。本ポートフォリオでは 0-switch(単一遷移)カバレッジを採用し、1-switch 以上(2連続遷移)は組合せ爆発を考慮しスコープ外とした。Closed は事実上の終了状態として扱う。

遷移	区分	根拠要件	対応TC
Open → In Progress / Pending	許可	RQ-036	TC-021 / TC-030
In Progress → Resolved / Pending	許可	RQ-037	TC-022 / TC-025
Pending → In Progress	許可	RQ-038	TC-023
Resolved → Closed	許可	RQ-039	TC-027
Open → Closed(直接クローズ)	禁止	RQ-040	TC-020
Closed → 他状態すべて	禁止	RQ-041	TC-028

(v1.6)本状態遷移モデル(許可/禁止エッジ)と §3.2 のデシジョンテーブル R1-R6 は、runn API 層(API-B:valid_edges / invalid_transitions / role_constraints)で網羅的に検証している。全 5×5 の遷移可否マトリクスは別紙「デシジョンテーブル.xlsx(状態遷移モデル)」を参照。

3.2 権限マトリクス(Decision Table — ステータス変更操作の認可)

本表は「ステータス変更操作を実行する認可があるか」を表す。遷移先の妥当性(Open→Closed 禁止 等)は §3.1 の状態遷移モデル側で定義されており、本表の「許可」と AND 条件を満たす場合のみ実際に状態が更新

される(実装: views.ticket_change_status で両者を直列にチェック)。採用記法＝混合指定表(Mixed-entry table) : 多値条件 C2 は1行で表現し、Y/N を3行に展開しない。

条件・動作 \ ルール	R1	R2	R3	R4	R5	R6
C1: 現在ステータス = Closed	Y	N	N	N	N	N
C2: ロール	—	Admin	Agent	Agent	Agent	Requester
C3: 担当者が割当済	—	—	Y	Y	N	—
C4: 担当者 = 自分(ログインユーザ)	—	—	Y	N	—	—
A1: ステータス変更操作を許可	—	X	X	—	—	—
A2: ステータス変更操作を禁止	X	—	—	X	X	X

凡例: Y/N＝条件を満たす／満たさない、—＝don't care (他条件で結論が確定)、X＝当該動作が選択(列ごとに A1/A2 は排他)。

ルールの読み方: R1＝Closed は他条件を問わず変更禁止(終了状態)／R2＝Admin は常に許可(Closed 以外)／R3＝Agent は「担当が自分」のときのみ許可／R4＝Agent でも「担当が他人」なら禁止／R5＝Agent でも「担当未割当」なら禁止(RQ-034)／R6＝Requester は常に禁止。

要件・テストとの対応(一次ソース:70トレーサビリティ)

ルール	主な対応要件	主な対応TC(手動)	API層(runn)
R1	RQ-041	TC-028	—
R2	RQ-032(一部)	TC-021 / TC-022 / TC-025 / TC-027 / TC-030	API-B3(R2)・API-A5
R3	RQ-029	(Backlog: TC追加候補＝Agent 自担当の許可は手動TC未整備)	API-B3(R3) が網羅(v1.4)
R4	RQ-029	TC-007 / Auto-04	API-B3(R4)
R5	RQ-034	TC-008	API-B3(R5)
R6	RQ-026	TC-004 / TC-005	—

※ R3(Agent が自分の担当を変更＝許可)は手動テストケースが未整備(Backlog)。ただし runn API 層(API-B3 role_constraints)が R3-R5 を網羅している(v1.4)。この「手動の穴」を隠さず明示する。

3.3 同値分割・境界値分析(Boundary Value Analysis)

各入力項目について、無効下限／有効下限／有効上限／無効上限の4点を整理する(ISTQB FL「3点境界値」準拠の表現)。

項目	無効下限	有効下限	有効上限	無効上限	主な対応TC
title(必須・最大80文字)	0文字(空)	1文字	80文字	81文字	TC-033 / 034 / 035
body(必須・最大4000文字)	0文字(空)	1文字	4000文字	4001文字	TC-033 / 045 / 046
due_date(任意・過去日不可)	昨日(過去)	当日	(上限なし)	(該当なし)	TC-036
添付サイズ(任意・最大5MB)	(該当なし)	1B	5MB(5,242,880B)	5MB+1B	TC-038
添付拡張子	不許可拡張子	png/jpg/jpeg/pdf/txt	同左	同左以外	TC-039

注: title / body の「無効下限=0文字」は必須エラー(同値クラス:未入力)として TC-033 で集約検証。due_date の上限は仕様上未定義。添付サイズの「無効下限=0B」は実装上発生し得ない(アップロード不成立)ため対象外。(v1.6) title/body の4点境界は runn API-C(title_body_boundary)、due_date の過去日/不正値は API-C(due_date)で検証。添付境界は API テスト対象外(E2E/手動に残置)。

4. カバレッジアイテム (Coverage Items)

- ・ ロール: 依頼者 / 担当者 / 管理者
- ・ ステータス: Open / In Progress / Pending / Resolved / Closed
- ・ 遷移: 許可遷移 (○) と禁止遷移 (×)
- ・ 入力制約: 必須、文字数境界、期限、添付 (サイズ / 形式)
- ・ 一覧・検索: キーワード、状態フィルタ、ソート

5. テストチャーター (探索的テスト)

チャーター1 (30分)

目的: 権限と直接アクセスの抜けを見つける。範囲: 一覧 / 詳細 / 更新 (URL 直叩き、ID 変更、ボタン表示)。着眼点: 参照・更新・割当がロールどおりか、エラー表示の分かりやすさ。

チャーター2 (30分)

目的: 状態遷移と履歴の破綻を見つける。範囲: 遷移操作、コメント、履歴表示。着眼点: 禁止遷移、二重クリック、戻る / 更新、履歴の時系列。

6. テストデータ・環境要件

テストデータ (アカウント・チケット・添付) と実行環境 (OS/ブラウザ/CI) は 40_test_environment.md を正本とする。認可・遷移の境界を突くための代表データを以下に示す (seed_demo、共通パスワード pass1234)。

ユーザー / チケット	ロール / 状態	検証目的
requester1	Requester	自分のチケットのみ閲覧・起票 (RQ-015 / R6)
requester2	Requester	他人チケットの所有者。IDOR の相手役 (TC-002/003)
agent1 / agent2	Agent	全閲覧・担当分のみ更新 / 非担当・未割当の拒否 (R3-R5)
admin1	Admin	全操作・割当・期限・ステータス遷移 (R2)
Ticket #1 / #2	Open 等	未割当→割当、他人チケット (IDOR)、遷移の直接操作拒否

境界値・同値クラスの入力パターン (過去日 / 上限サイズ / 不許可拡張子 等) は §3.3 を参照。

7. 自動化対象の選定基準

以下の条件を満たすケースを Playwright (E2E) / runn (API) による自動化対象とする。

- ・ 繰り返し実行が必要なスモークテスト
- ・ 複数のロール (Admin / Agent / Requester) を跨ぐ権限確認
- ・ データ投入から確認までの一連のハッピーパス
- ・ 実欠陥 (DEFECT-001 IDOR、DEFECT-002 body 長制約) の回帰防止: 起票・修正したバグの再発を CI で即時検知
- ・ 要件と実装の整合性チェック: 境界値や認可ルールなど、要件側で「Must / 拒否」と定義したケースの実装妥当性を継続検証

8. テスト層戦略 (要約: 80_test_layer_strategy)

認可マトリクスと状態遷移は本質的に組合せが爆発する。E2E で網羅すると遅く・脆く・観測点が粗い。これらは入力に対し期待結果が一意に決まる決定的な世界にあるため、速く決定的に叩ける API/インテグレーション層へ押し下げ、E2E は代表シナリオに絞る。

レイヤ	担うもの	規模
手動 TC	仕様の深掘り・探索的・ユーザビリティ	46件
API / runn(新設)	認可マトリクス・IDOR・状態遷移・入力境界値の組合せ網羅	10 runbook / 102 step
E2E / Playwright(再配分)	代表導線+認可スモーク+UI 抑止+実欠陥回帰	4シナリオ

runn 内訳:(a) 認可+IDOR=5 runbook/43 step、(b) 状態遷移=3 runbook/43 step、(c) 入力検証=2 runbook/16 step。

期待値の写像(決定的な世界の体现):HTML が「拒否はすべて 403 文言」で表すのに対し、API は意味的に正しい HTTP ステータスへ一意に写像できる。

結果	HTML	API	意図
読取 / 更新 成功	200 / 302	200(作成 201)	リソースを返す
未認証	302→login	401	Token 認証
認可拒否(ロール/所有/IDOR)	403	403	IDOR も忠実にミラー
不正ステータス値(enum 外)	403	400	入力不正
不正遷移(enum 内・禁止エッジ)	403	409 Conflict	状態競合
文字数超過 / 過去日	200 / 500(DEFECT-003)	400	検証エラー
不在 pk	404	404	ミラー

E2E 再配分:Auto-01 ハッピーパス=KEEP/Auto-02 IDOR 回帰=KEEP(認可スモーク)/Auto-03 本文 4001境界=API 層へ MOVE(削除)/Auto-04 非担当 Agent UI 抑止=KEEP(UI のみ、サーバ側認可は runn へ)/Auto-05 期限過去日の graceful 拒否=ADD。単一ソース:認可・状態遷移の判定を policy.py に一本化し、INTENTIONAL_BUG_IDOR=True で API の IDOR テストと E2E Auto-02 が同一原因で同時に失敗する(テストが本物を見ている担保)。

9. 検出欠陥サマリ

設計・実行を通じて実バグ 3件を検出し、起票 → 修正 → 回帰まで完遂した。うち 2件は自動テストの期待値設計が炙り出した。

欠陥ID	タイトル	重要度	関連TC	検出経緯
DEFECT-001	依頼者が他人チケット詳細を参照できる(IDOR)	Critical	TC-002/003	意図的欠陥(IDOR=ON)の再現と検出
DEFECT-002	本文(body)の最大長制約が enforce されていない	High	TC-046	本文境界の自動化(Auto-03 昇格)時に発見
DEFECT-003	期限の過去日入力で 500(full_clean 例外未処理)	Medium	TC-036 / Auto-05	runn API 層の期待値(過去日→400)が HTML 側不具合を炙り出した

用語定義

本書で用いる用語は JSTQB FL シラバスの定義に基づく。

用語	定義
デシジョンテーブルテスト	テスト条件の組合せに対するシステムの振る舞いを検証する技法
混合指定表(Mixed-entry)	多値条件を1行で表現するデシジョンテーブルの記法
状態遷移テスト / 0-switch	状態と遷移に基づく技法。0-switch は単一遷移カバレッジ
境界値分析 / 同値分割	境界・代表値に基づくテスト技法
探索的テスト	チャーターに基づき学習・設計・実行を同時に行う技法
IDOR	Insecure Direct Object Reference。識別子の直接参照による認可バイパス